Usama Arshad.

OFFENSIVE SECURITY LEAD · RED TEAM · FINTECH & CLOUD

Riyadh, Saudi Arabia
gusama21@gmail.com
usamaarshad.me

GitHub github.com/usama0x01 · **LinkedIn** in/usama0x01 · **X** @usama0x01 · **Bugcrowd** Xam_3xPloiTeR · **Synack SRT** usama-arshad · **Medium** @usama0x01

Profile

OSCP-certified Offensive Security Lead with **9+ years** across red team, application security, and cloud — spanning web, mobile, API, GCP, AWS, and Kubernetes. Currently leads the offensive security function at **Tabby**, MENA's largest BNPL fintech (**14M+ users**), where I build autonomous VAPT pipelines, embed AppSec gates into GitLab CI/CD, and harden GKE workloads. **80+ engagements** delivered for Fortune 500 companies and SAMA-regulated financial institutions — and an active vulnerability-research habit that turns exploitation chains into decisions executives can act on.

Vulnerability Research & Disclosure

CVE-2024-3681 CVSS 6.1 · MEDIUM · CWE-79 · PUBLISHED 2024

Reflected Cross-Site Scripting in a WordPress interactive-maps plugin (affected ≤ v2.4.14) — original discovery and coordinated responsible disclosure. Assigned CVE ID; CNA: Wordfence.

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

CATALOGUED BY NVD · MITRE · WORDFENCE

59+	8	121+
VULNERABILITIES REPORTED TO WPSCAN	VERIFIED & ACCEPTED — PEAKED 13TH ON THE WPSCAN LEADERBOARD	FINDINGS QUEUED FOR REVIEW · CVE IDS PENDING

SELECTED HIGH-IMPACT FINDINGS — REPORTED TO WPSCAN, CVE PENDING

CVSS 8.1	Unauthenticated IDOR → customer booking records & PII disclosure	UNAUTHENTICATED · WP TRAVEL-BOOKING PLUGIN · REPORTED TO WPSCAN — CVE PENDING
CVSS 7.5	Unauthenticated sensitive-data disclosure — member names (incl. minors), home address & GPS	UNAUTHENTICATED · WP MEMBERSHIP / MANAGEMENT PLUGIN · CVE PENDING
CVSS 7.5	Unauthenticated IDOR → any user's private support-ticket contents	UNAUTHENTICATED · WP HELPDESK PLUGIN · CVE PENDING
CVSS 7.5	Unauthenticated price / order-total manipulation	UNAUTHENTICATED · WP E-COMMERCE ORDERING PLUGIN · CVE PENDING
CVSS 7.1	Cross-tenant vendor IDOR → another vendor's paid downloadable files	AUTHENTICATED (VENDOR) · WP MULTI-VENDOR MARKETPLACE PLUGIN · CVE PENDING

Findings are reproduced in a local WordPress lab, deduplicated against the NVD / Patchstack catalogue, and reported through WPScan under coordinated disclosure. Affected plugin names and proof-of-concept detail are withheld while vendors ship fixes and CVE IDs are assigned. Leaderboard standing: **peaked at 13th** (Top-15) on the WPScan researcher board — a rolling window, currently 15th. Full disclosure log: usamaarshad.me/research

Experience

JUN 2025 — PRESENT
Riyadh, Saudi Arabia
CURRENT

Offensive Security Lead

Tabby · MENA's largest BNPL fintech

- Lead the offensive security function for **14M+ users**: red team, AppSec, and cloud security across web, mobile, API, GCP, and GKE.
- Architected autonomous VAPT dashboards with Jira / tracker automation — **cut assessment cycle time 60%** and eliminated manual reporting.
- Run continuous red team and adversary simulations, surfacing real-world attack chains before release.
- Embedded SAST, DAST, secret scanning, and container scanning into GitLab CI/CD, gating insecure releases at merge time.
- Hardened GKE workloads via Workload Identity, network policies, admission controllers, and runtime detection.

AUG 2024 — MAY 2025
Riyadh, Saudi Arabia

ISM Consultant & Team Lead

SecurEyes

- Led large-scale **SAMA** fintech security assessments for major Saudi financial institutions: end-to-end VAPT, source code review, red team.
- Full-scope red team operations: external / internal infrastructure, web, mobile, API, Active Directory, WiFi, physical, cloud, DLP/EDR evasion.
- Mentored consultants, reviewed deliverables, and presented findings to executives and regulators.

DEC 2021 — JUL 2024
Lahore, Pakistan

Senior Security Engineer
Ebryx

- Delivered **80+ offensive engagements** for Fortune 500 clients: pentesting, source code review, red teaming.
- Led a sub-team of consultants; owned scoping, execution, peer review, and report quality.
- Translated complex exploitation chains into business-impact narratives for executives.

MAR 2021 — PRESENT
Remote
PART-TIME

Red Team Member
Synack Red Team

- Continuous vulnerability discovery and exploitation on private enterprise targets.
- High-impact findings: IDOR, BOLA, authentication bypass, and business-logic flaws.

MAR 2018 — MAY 2021
Lahore, Pakistan

Penetration Tester
Security Wall

- Validated vulnerabilities across **50+ engagements** spanning web, mobile, and network.
- Built reusable internal tooling and methodologies that raised team throughput.

Areas of Expertise

01 RED TEAM & ADVERSARY SIMULATION
MITRE ATT&CK · Purple Team · Physical Intrusion · OSINT · Cobalt Strike · Sliver · Mythic · Initial Access · Lateral Movement · Persistence · Defense Evasion

02 OFFENSIVE TESTING
Web / OWASP Top 10 · Mobile / MASVS · iOS & Android · REST · GraphQL · gRPC · Network & Infrastructure · Active Directory · WiFi · Thick Client · Source Code Review

03 CLOUD & CONTAINER SECURITY
GCP · AWS · GKE / Kubernetes · Container Escape · IAM Privilege Escalation · Metadata Abuse · Workload Identity · Terraform IaC Scanning · CIS Benchmarks

04 APPSEC & DEVSECOPS
GitLab CI/CD Security Gates · SAST · DAST · SCA · Secret Scanning · Threat Modeling / STRIDE · Secure SDLC · Code Review — Python / Go / Node / Java

05 TOOLING & AUTOMATION
Burp Suite Pro · Frida · Ghidra · IDA · Nmap · Nuclei · Nessus · Metasploit · BloodHound · Sliver · FFUF · Sqlmap · Wireshark · Custom Python & Go

06 COMPLIANCE & FRAMEWORKS
SAMA CSF · PCI DSS · ISO 27001 · OWASP ASVS · NIST CSF

Achievements

BlackHat MEA CTF — Finalist — 2023 · 2024
Top 32 (2023) and Top 29 (2024) of 250+ teams globally, representing Pakistan.

National CTF Hat-Trick — 2021 — 2023
Podium finishes at Pakistan's national cyber hackathon three consecutive years — awarded by the President, the Prime Minister, and the IT Minister.

Four Halls of Fame — ×4
Responsible-disclosure recognition from the **United Nations**, **Walmart**, **Achmea**, and **The Sun**.

Speaker — ONGOING
Recurring talks at universities and security conferences on offensive security and AI-driven attack automation.

Certifications & Education

OSCP Offensive Security Certified Professional
OFFENSIVE SECURITY

HTB Offshore Pro Lab — Active Directory & banking infrastructure
HACK THE BOX

PEH Practical Ethical Hacker
TCM SECURITY

CNSS Certified Network Security Specialist
ICSI

EDUCATION
BSc Computer Science
COMSATS University, Lahore · 2018 — 2021

LANGUAGES
English — Professional · **Urdu** — Native